

Évasion de Détection dans les Environnements Zero-Trust

Une analyse critique des limites structurelles des architectures actuelles

Auteur : Sidali

RÉSUMÉ

Le modèle Zero-Trust s'est imposé depuis 2020 comme paradigme dominant en cybersécurité, porté par des cadres normatifs majeurs (NIST SP 800-207, guide ANSSI-PA-111, CISA Zero Trust Maturity Model v2.0). Pourtant, les déploiements opérationnels reposent sur trois hypothèses fortes, intégrité du fournisseur d'identité, complétude de la télémétrie, rigueur de la micro-segmentation, que des acteurs sophistiqués exploitent désormais de manière systématique. Ce rapport propose une analyse critique de quatre vecteurs d'évasion structurels : l'abus du fournisseur d'identité (IdP), les angles morts télémétriques liés au trafic chiffré (HTTPS, DoH), les défauts de micro-segmentation, et le détournement de jetons de session. Chaque vecteur est cartographié dans MITRE ATT&CK, illustré par des incidents publics (Okta 2023, Scattered Spider), et confronté à un scénario expérimental de simulation. Le rapport conclut par une grille d'évaluation de maturité Zero-Trust en huit dimensions, destinée à objectiver le niveau réel de couverture d'une architecture face à l'évasion.

Mots-clés : Zero-Trust, NIST SP 800-207, ANSSI, MITRE ATT&CK, détection d'intrusion, évasion, micro-segmentation, IdP, session hijacking, homologation.

1. Introduction

Depuis la publication de la NIST Special Publication 800-207 en 2020, puis l'Executive Order 14028 du gouvernement américain imposant aux agences fédérales l'adoption progressive du modèle Zero-Trust, ce paradigme s'est imposé comme la grammaire de référence de la cybersécurité moderne. En France, l'Agence nationale de la sécurité des systèmes d'information (ANSSI) a publié en 2021 un avis scientifique et technique sur le sujet, complété en juin 2025 par le guide ANSSI-PA-111, Modèle Zero Trust : les fondamentaux, qui en formalise l'intégration dans une stratégie de défense en profondeur.

Cette consécration normative s'est accompagnée d'une rhétorique marketing abondante. La promesse, (ne jamais faire confiance, toujours vérifier), est séduisante par sa simplicité. Elle laisse cependant supposer que l'application des principes Zero-Trust suffirait à neutraliser les menaces internes et le mouvement latéral, deux fléaux historiquement associés au modèle périmétrique traditionnel. La réalité opérationnelle est nettement plus nuancée.

Le Verizon Data Breach Investigations Report 2025 rappelle que l'abus d'identifiants demeure le premier vecteur d'accès initial dans 22 % des compromissions observées sur plus de 22 000 incidents analysés, et que 88 % des attaques contre les applications web reposent sur des identifiants volés. La montée des techniques de contournement de l'authentification multifacteur (MFA), du vol de jetons et des attaques adversary-in-the-middle remet directement en cause la promesse fondamentale du Zero-Trust : la vérification continue de l'identité.

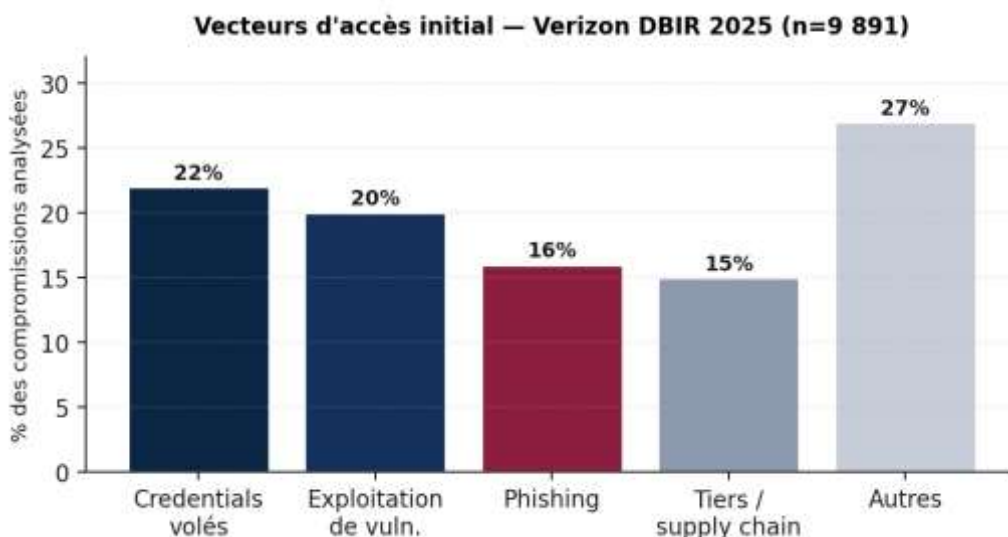


Figure 1, Distribution des vecteurs d'accès initial selon le Verizon DBIR 2025. L'abus d'identifiants reste le vecteur dominant malgré le déploiement massif des architectures Zero-Trust.

L'ANSSI elle-même met en garde dans son guide PA-111 contre l'illusion d'une rupture entre Zero-Trust et défense périmétrique : le recours à des solutions logicielles nouvelles et nombreuses multiplie le risque de perte de contrôle, donnant ainsi un faux sentiment de sécurité. Cette mise en garde institutionnelle invite à un examen critique des implémentations.

Question de recherche. Quelles sont les limites structurelles des architectures Zero-Trust telles qu'elles sont déployées aujourd'hui, et comment un attaquant disposant d'un point d'entrée initial peut-il exploiter ces limites pour échapper à la détection tout en progressant dans le système d'information ?

Contribution. Ce rapport propose (1) une analyse en quatre vecteurs des angles morts du Zero-Trust, chaque vecteur étant cartographié dans MITRE ATT&CK et illustré par des incidents documentés ; (2) un scénario expérimental simulé sur le vecteur de détournement de jetons ; (3) une grille d'évaluation de maturité Zero-Trust en huit dimensions, directement utilisable dans une démarche d'homologation au sens de l'instruction interministérielle française et des guides ANSSI BP-028/BP-030.

Périmètre. Le présent rapport ne couvre pas la conception ex nihilo d'une architecture Zero-Trust, ni les questions de gouvernance RGPD/NIS2 stricto sensu. Il se concentre sur la défense en profondeur côté détection et sur la confrontation entre les hypothèses du modèle et les techniques d'évasion documentées dans MITRE ATT&CK.

2. Fondamentaux Zero-Trust et modèle de menace

2.1 Le cadre NIST SP 800-207 et l'apport ANSSI

La NIST SP 800-207 définit le Zero-Trust non comme une technologie mais comme un ensemble de principes architecturaux organisés autour de sept préceptes (tenets). Parmi les plus structurants figurent : (i) toute donnée et tout service est traité comme une ressource ; (ii) toute communication est sécurisée indépendamment de la localisation réseau ; (iii) l'accès est accordé par session, selon le principe de moindre privilège ; (iv) la décision d'accès est dynamique, fondée sur des attributs contextuels (identité, posture du poste, sensibilité de la ressource) ; (v) l'entreprise collecte un maximum d'informations sur ses actifs pour améliorer sa posture de sécurité.

L'architecture logique repose sur un triptyque : un Policy Engine (PE) qui décide, un Policy Administrator (PA) qui configure et un Policy Enforcement Point (PEP) qui applique. Le PEP est interposé entre le sujet (utilisateur, machine, service) et la ressource demandée.

Architecture Zero-Trust selon NIST SP 800-207 (vue logique)

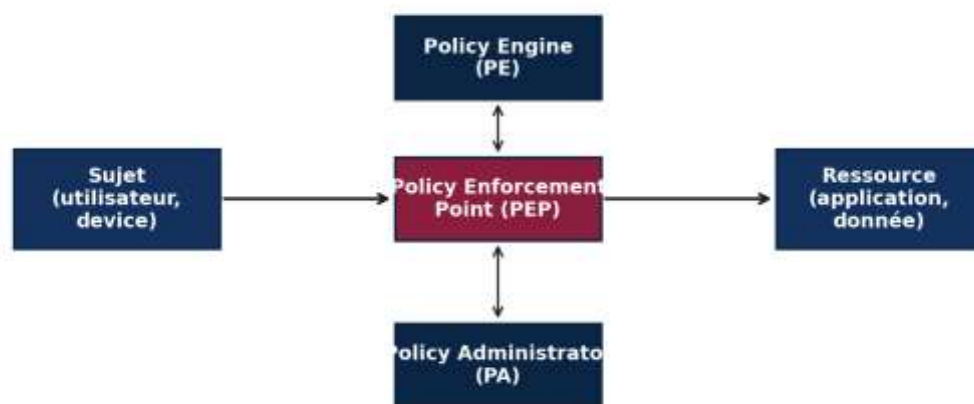


Figure 2 - Architecture logique Zero-Trust selon NIST SP 800-207. Tout flux passe par un PEP qui interroge le PE avant d'autoriser ou de refuser. La sécurité repose entièrement sur la qualité des attributs transmis au PE.

Le guide ANSSI-PA-111 apporte une nuance essentielle : le modèle Zero-Trust « doit être inclus dans une stratégie de défense en profondeur et ne doit en aucun cas être vu comme un remplacement d'une défense périmétrique ». L'ANSSI recommande six axes d'effort prioritaires : assainissement du référentiel d'identité, authentification forte, renforcement des moyens de détection (SIEM), configuration des services à l'état de l'art (guide TLS de l'ANSSI), conduite du changement, et exclusion stricte des postes d'administration du périmètre Zero-Trust standard.

2.2 Les trois hypothèses structurelles du modèle

L'efficacité du Zero-Trust repose, en pratique, sur trois hypothèses rarement explicitées dans les déploiements opérationnels :

H1	Intégrité du fournisseur d'identité. Le PE prend ses décisions à partir d'attributs émis par un IdP (Okta, Entra ID, Keycloak...). Si l'IdP est compromis ou mal configuré, l'ensemble de la chaîne de confiance s'effondre.
H2	Complétude et fiabilité de la télémétrie. Le contrôle continu suppose que le système observe l'intégralité des flux pertinents. Or, le chiffrement de bout en bout (TLS 1.3, DoH, DoT, QUIC) et l'usage croissant de services cloud légitimes créent des angles morts irréductibles pour les outils SIEM/EDR/NDR.
H3	Granularité effective de la micro-segmentation. La promesse d'isoler chaque charge de travail suppose des politiques fines et à jour. En pratique, l'inflation des règles autorisantes pour ne pas casser la production conduit à des politiques trop permissives que les attaquants exploitent pour le mouvement latéral.

C'est sur la fragilité de ces trois hypothèses que repose toute la démarche de ce rapport. Chacun des vecteurs analysés en section 3 exploite l'une, parfois plusieurs, de ces hypothèses.

2.3 Modèle de menace retenu

Nous adoptons un modèle assume breach conforme aux préconisations du guide ANSSI-PA-111 et du CISA Zero Trust Maturity Model v2.0 : l'attaquant a déjà acquis un point d'entrée initial. Ce postulat est réaliste : selon le DBIR 2025, le délai médian d'identification et de containement d'une compromission impliquant des identifiants compromis était de 246 jours en 2024.

Capacités de l'attaquant. Acteur sophistiqué de niveau Scattered Spider ou équivalent : maîtrise de l'ingénierie sociale, capacité à exfiltrer des cookies de session via infostealer ou fichier HAR, accès à des outils de C2 modernes (Cobalt Strike, Sliver) configurés pour s'appuyer sur HTTPS et DoH.

Objectifs de l'attaquant. Maintien d'un accès persistant, élévation de privilèges via abus de l'IdP, mouvement latéral entre charges de travail micro-segmentées, exfiltration de données.

Hors périmètre. Attaques DDoS, exploitation de vulnérabilités matérielles, compromission physique des infrastructures.

3. Analyse de la surface d'attaque

Cette section constitue la contribution principale du rapport. Quatre vecteurs sont analysés. Pour chacun, nous identifions : le mécanisme exploité, l'hypothèse Zero-Trust mise en défaut, la technique MITRE ATT&CK associée, un incident public illustratif, et l'écart typique de détection observé.

3.1 Vecteur 1, Abus du fournisseur d'identité (IdP)

Hypothèse mise en défaut : H1 (intégrité de l'IdP). **Techniques MITRE :** T1556, T1556.007, T1556.009.

Dans une architecture Zero-Trust, l'IdP joue le rôle de source de vérité unique. La compromission d'un compte administrateur Okta, Entra ID ou JumpCloud, ou l'altération d'un agent de synchronisation hybride (PTA, AD FS), permet à l'attaquant non seulement d'usurper n'importe quelle identité mais aussi de désactiver silencieusement les politiques d'accès conditionnel.

Incident de référence : Okta, septembre-octobre 2023. Entre le 28 septembre et le 17 octobre 2023, un acteur malveillant a obtenu un accès non autorisé au système de gestion des cas support d'Okta, exploitant un compte de service stocké dans le système lui-même. Le délai entre la compromission et la détection a été de quatorze jours. Trois clients d'Okta (1Password, BeyondTrust et Cloudflare) ont détecté l'activité suspecte avant qu'Okta ne les notifie. L'attaquant a pu récupérer 134 fichiers HAR contenant des jetons de session actifs et hijacker cinq sessions de clients.

Le rapport ReliaQuest publié fin 2023 documente par ailleurs un cas où le groupe Scattered Spider a obtenu, via ingénierie sociale d'un administrateur IT et accès Okta SSO, un mouvement latéral entre l'IDaaS et les actifs on-premises de la cible en moins d'une heure.

Écart de détection. Les logs Okta System Log capturent bien les événements pertinents, mais leur volume et leur format obscur rendent la détection en quasi-temps réel difficile. La binding des jetons d'administrateur Okta à l'ASN n'est pas activée par défaut et doit être explicitement configurée par le client — un exemple typique de défaut de configuration secure-by-default.

3.2 Vecteur 2, Angles morts télémétriques

Hypothèse mise en défaut : H2 (complétude de la télémétrie). **Techniques MITRE :** T1071.004, T1001.003, T1041.

Le précepte n°7 de la NIST SP 800-207 stipule que l'organisation collecte « le plus d'informations possibles » sur ses actifs. En pratique, cette ambition se heurte à trois obstacles : la généralisation du chiffrement TLS 1.3 (qui masque les SNI via ECH), le déploiement de DNS-over-HTTPS (DoH) et DNS-over-QUIC (DoQ), et l'usage légitime de services cloud (Microsoft 365, AWS, Cloudflare) comme infrastructure de C2.

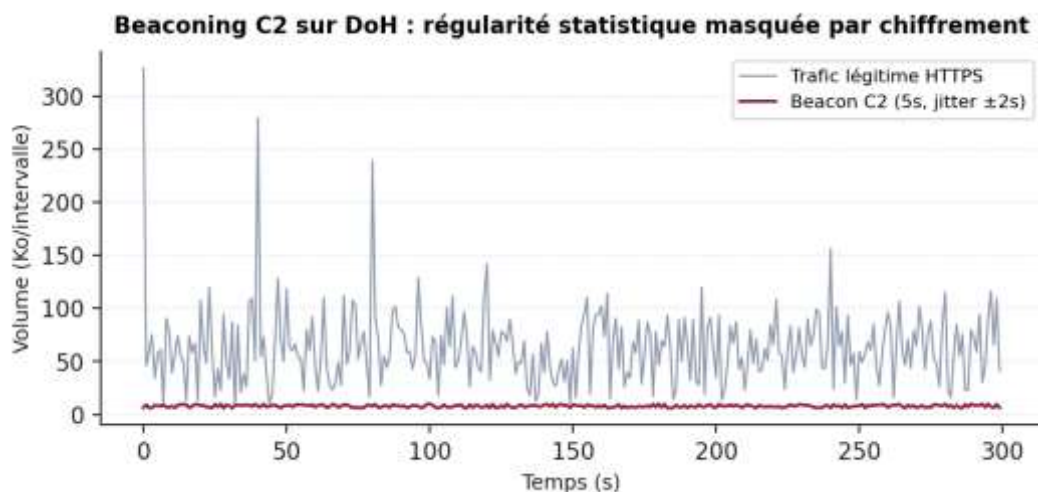


Figure 3 - Comparaison schématique entre trafic HTTPS légitime (variable) et beacon C2 sur DoH (quasi-constant avec faible jitter). Sans inspection TLS, seule l'analyse comportementale du timing permet la détection.

Le projet Active Countermeasures a publié en janvier 2026 une comparaison des canaux C2 fondés sur DNS, DoT, DoH et DoQ : tous passent indétectables au niveau réseau sans interception TLS. Les frameworks tels que Cobalt Strike (profils Malleable C2) ou Sliver permettent par défaut d'imiter le fingerprint d'une application légitime jusqu'au niveau des en-têtes HTTP.

Écart de détection. Une étude académique de 2022 (FEUP/INESC TEC) montre qu'un détecteur fondé sur l'apprentissage automatique reste capable d'identifier le trafic Metasploit chiffré en condition de laboratoire, mais que la même approche perd significativement en efficacité face à un adversaire qui adapte ses profils de trafic (adversarial learning). Le coût opérationnel d'une détection robuste reste largement sous-estimé dans les démarches Zero-Trust commerciales.

3.3 Vecteur 3, Défauts de micro-segmentation

Hypothèse mise en défaut : H3 (granularité effective). **Techniques MITRE :** T1021, T1210, T1570.

La micro-segmentation est présentée comme la pierre angulaire de la limitation du blast radius. Le guide de la CISA sur la micro-segmentation Zero-Trust (juillet 2025) reconnaît cependant que sa mise en œuvre suppose un équilibre délicat entre sécurité, performance et opérabilité. En pratique, les politiques fines sont rarement maintenues à jour : la rotation rapide des charges de travail dans les environnements Kubernetes, l'introduction continue de nouveaux microservices, et la pression opérationnelle conduisent à des règles dites (allow east-west by default) qui préservent la communication entre services au prix de la sécurité.

Le DBIR 2025 et le rapport IBM Cost of a Data Breach 2025 convergent sur un constat : le mouvement latéral post-compromission s'effectue en moyenne en moins de 48 minutes, alors que la durée moyenne d'un cycle de revue de politiques de segmentation dans une entreprise se compte en semaines, voire en mois. L'asymétrie temporelle est structurelle.

Le travail de Basta et al. (arXiv:2111.10967) propose une méthodologie graphique d'évaluation de la robustesse d'une micro-segmentation, fondée sur les graphes de connectivité et d'attaque. Ce type d'évaluation analytique reste à ce jour peu implémenté en production.

Écart de détection. Une politique de micro-segmentation permissive ne déclenche aucune alerte par construction : l'attaquant emprunte des flux autorisés. La détection ne peut alors reposer que sur l'analyse comportementale (UEBA).

3.4 Vecteur 4, Détournement de jetons de session

Hypothèses mises en défaut : H1 et H2. **Techniques MITRE :** T1539, T1550.004, T1606.

Le Zero-Trust suppose une authentification continue, généralement implémentée via des jetons à durée de vie courte (OAuth, OIDC, SAML). Or, la durée de vie « courte » est rarement inférieure à une heure en pratique, et plusieurs scénarios permettent à un attaquant de récupérer un jeton actif :

- Pass-the-cookie via infostealer (Lumma, RedLine, Atomic Stealer) qui exfiltre les cookies de session depuis le navigateur, contournant intégralement le MFA puisque l'authentification est déjà acquise ;
- Adversary-in-the-Middle via Evilginx2, qui intercale un proxy transparent entre la victime et le portail légitime et capture en temps réel les tokens MFA ;
- Exfiltration de fichiers HAR (cas Okta 2023) lorsque les jetons sont stockés dans des artefacts de débogage transitant par des canaux non chiffrés.

Le DBIR 2025 documente que 88 % des attaques contre les applications web exploitent des identifiants compromis et que les techniques de contournement de MFA (prompt bombing, token theft, AitM) sont en forte progression.

Écart de détection. Le détournement de jeton ne produit aucune anomalie d'authentification puisqu'aucune authentification n'a lieu : le jeton volé est joué tel quel. Les seuls signaux exploitables sont contextuels : changement de géolocalisation (impossible travel), changement d'ASN, anomalie du fingerprint TLS client.

Synthèse des quatre vecteurs

Vecteur	Hypothèse	Technique MITRE	Détection typique
IdP abuse	H1	T1556 / .007 / .009	Logs IdP, ITDR
Télémetrie	H2	T1071.004 / T1041	NDR, UEBA, beaconing
Micro-segmentation	H3	T1021 / T1210 / T1570	UEBA, graphe d'attaque
Session hijack	H1 + H2	T1539 / T1550.004	Impossible travel, ASN

Tableau 1 - Synthèse des quatre vecteurs d'évasion analysés.

4. Scénario expérimental

Cette section décrit un scénario simulé visant à valider, à l'échelle d'un laboratoire personnel, la principale conclusion du vecteur 4 : le détournement de jeton de session ne produit pas d'anomalie d'authentification détectable sans corrélation contextuelle.

4.1 Environnement de laboratoire

L'environnement est construit sur VMware Workstation 17 et GNS3. Il comporte les composants suivants :

Composant	Rôle	Configuration
VM-IdP	Fournisseur d'identité (Keycloak 24)	Ubuntu 22.04, 4 Go RAM, OIDC + MFA TOTP
VM-App	Application web protégée	Ubuntu 22.04, Flask + python-keycloak, reverse proxy NGINX
VM-PEP	Policy Enforcement Point	NGINX + oauth2-proxy, journaux JSON vers ELK
VM-SIEM	Stack ELK 8	Ubuntu 22.04, 8 Go RAM, ingestion logs IdP + PEP + NetFlow
VM-Attaquant	Poste offensif	Kali Linux, Mitmproxy, Evilginx2, scripts Python custom
VM-Victime	Poste utilisateur légitime	Windows 11, Chromium, MFA TOTP enrôlé

Tableau 2 - Composition du laboratoire de simulation.

Le périmètre est strictement isolé du réseau de l'université (VMware Host-Only Network, plage 192.168.56.0/24). Aucun trafic réel d'attaque ne quitte le laboratoire.

4.2 Méthodologie et résultats

Le scénario reproduit, de manière simplifiée, le mode opératoire documenté dans l'incident Okta 2023 et les rapports Microsoft « Token tactics » :

- Étape 1 : Authentification légitime. La VM-Victime s'authentifie auprès de Keycloak avec mot de passe + TOTP. Un jeton OIDC est émis et stocké dans un cookie de session HttpOnly.
- Étape 2 : Simulation d'exfiltration. Un script Python sur la VM victime simule l'action d'un infostealer en copiant le cookie de session vers un fichier transmis à la VM-Attaquant.
- Étape 3 : Rejeu du jeton. La VM-Attaquant injecte le cookie dans un nouveau navigateur (curl + cookie jar) et accède directement à l'application protégée, sans déclencher de challenge MFA.
- Étape 4 : Observation côté SIEM. Analyse des logs Keycloak, NGINX/oauth2-proxy et flux NetFlow centralisés dans Kibana.

Les requêtes types observées côté PEP (extrait anonymisé) :

```
# Requête légitime (VM-Victime)
GET /app/dashboard HTTP/1.1
Host: app.lab.local
Cookie: kc_session=eyJhbGciOiJSUzI1NiIs...
User-Agent: Chrome/128.0 Win64
X-Forwarded-For: 192.168.56.20

# Requête malveillante (VM-Attaquant, après rejeu)
GET /app/dashboard HTTP/1.1
Host: app.lab.local
Cookie: kc_session=eyJhbGciOiJSUzI1NiIs... # IDENTIQUE
User-Agent: curl/8.5.0 # DIFFÉRENT
X-Forwarded-For: 192.168.56.50 # DIFFÉRENT
```

4.3 Analyse des écarts de détection

Trois constats émergent de l'observation des logs :

Signal observable	Détection auto. (défaut)	Après règle dédiée
Anomalie d'authentification Keycloak	Non (aucune auth.)	/
Changement d'IP source du même cookie	Non	Oui (règle ELK)
Changement de User-Agent	Non	Oui (règle ELK)
Impossible travel géographique	Non (lab mono-site)	N/A
Fréquence d'accès anormale	Non	Oui (UEBA/ML)

Tableau 3 - Capacités de détection avant et après ajout de règles dédiées.

Conclusion expérimentale. Conformément à l'hypothèse de la section 3.4, le rejeu de jeton ne produit aucune anomalie d'authentification, et les signaux contextuels (IP, UA, fréquence) ne sont exploitables qu'après ajout explicite de règles de corrélation. Dans une configuration « out-of-the-box » d'une stack ELK et d'un oauth2-proxy, l'attaque est indétectable. Ce résultat est cohérent avec les constats d'incident Okta 2023 : ce sont les clients qui ont détecté l'activité suspecte avant l'éditeur lui-même.

Limites du dispositif. Le laboratoire n'inclut pas de véritable infostealer, ni de trafic chiffré DoH, ni de variation géographique réelle. Une montée en puissance possible consisterait à intégrer un EDR ouvert (Wazuh) et à comparer ses capacités natives de corrélation avec celles obtenues par règles Kibana explicites.

5. Recommandations et mitigations

5.1 Mesures techniques par vecteur

Vecteur	Mesures techniques recommandées
IdP abuse	• Authentification phishing-resistant (FIDO2, passkeys) pour tous les administrateurs ; • Binding des jetons admin à l'ASN et à la posture du device ; • Séparation stricte des comptes administrateurs (PAW) conformément au guide ANSSI ; • Mise en place d'un ITDR (Identity Threat Detection & Response).
Télémétrie	• Déploiement d'un NDR capable d'analyse comportementale (beaconing par jitter) ; • Blocage par défaut des résolveurs DoH externes non maîtrisés ; • Inspection TLS sur les zones critiques avec gestion RGPD du périmètre ; • Centralisation SIEM des logs DNS internes.
Micro-segmentation	• Adoption d'une politique discover-simulate-enforce avant tout durcissement ; • Revue trimestrielle des règles autorisantes par graphe d'attaque ; • Rotation automatisée des secrets via HashiCorp Vault ; • Application du moindre privilège aux flux est-ouest.
Session hijack	• Durée de vie de jeton ≤ 15 min, refresh token rotatif ; • Binding du jeton au device (DPoP, mTLS client) ; • Détection systématique d'impossible travel et de changement d'ASN ; • Désactivation du stockage HAR avec cookies actifs côté support.

Tableau 4 - Mesures de mitigation par vecteur.

5.2 Cartographie ANSSI et MITRE ATT&CK

L'intérêt d'une cartographie croisée est double. D'une part, elle permet à une équipe de sécurité de prioriser ses investissements en liant chaque mesure technique à une technique d'attaque documentée dans MITRE ATT&CK. D'autre part, elle inscrit les contre-mesures dans un cadre institutionnel reconnu par les autorités françaises (ANSSI) et européennes (ENISA), ce qui facilite la communication avec la direction et la mise en conformité réglementaire (NIS2, LPM).

Vecteur	MITRE ATT&CK	Tactic	Recommandation ANSSI / NIST
IdP abuse	T1556, T1556.006, T1556.007, T1556.009	Credential Access / Persistence	ANSSI-PA-111 §3.2 ; Guide admin. sécurisée ANSSI ; NIST SP 800-63B AAL3
Télémétrie / C2	T1071.004, T1001.003, T1041	Command & Control / Exfiltration	ANSSI-PA-111 §4.3 ; Guide TLS ANSSI ; NIST SP 800-207 Tenet 7
Micro-seg.	T1021, T1210, T1570, T1563	Lateral Movement	ANSSI BP-028 §segmentation ; CISA ZT Maturity Model v2.0
Session hijacking	T1539, T1550.004, T1606	Credential Access / Defense Evasion	ANSSI-PA-111 §3.3 ; NIST SP 800-63B AAL3

Tableau 5 - Croisement MITRE ATT&CK / Tactic / ANSSI / NIST par vecteur.

La colonne Tactic rappelle dans quel phase de la chaîne d'attaque se situe chaque vecteur. Il est notable que tous se concentrent après l'accès initial (post-compromise), ce qui illustre le glissement du centre de gravité des attaques

modernes : l'objectif n'est plus de pénétrer le périmètre, mais de persister, d'élever ses privilèges et d'exfiltrer en restant sous le seuil de détection.

Priorité de déploiement. Si les ressources sont limitées, l'ordre de priorité recommandé est le suivant : (1) authentification phishing-resistant (impact maximal sur la chaîne de confiance), (2) corrélation contextuelle de session (faible coût, ROI détection élevé), (3) NDR comportemental (complexité d'intégration élevée mais couverture transversale), (4) révision des politiques de micro-segmentation (coût opérationnel fort, mais seule mesure agissant sur le mouvement latéral autorisé).

5.3 Grille de maturité Zero-Trust en huit dimensions

Cette grille constitue la contribution originale principale de ce rapport. Elle est conçue comme un outil d'auto-évaluation pratique, distinct des grilles de maturité existantes sur deux points essentiels.

Premièrement, le CISA Zero Trust Maturity Model v2.0 et le NIST SP 800-207A évaluent la maturité selon cinq piliers fonctionnels (Identité, Devices, Réseaux, Applications, Données) en mesurant le degré d'implémentation de chaque brique technologique. Cette approche est pertinente pour piloter une transformation, mais elle répond mal à la question : « est-ce qu'un attaquant peut contourner mes contrôles Zero-Trust aujourd'hui ? »

Deuxièmement, la grille proposée ici adopte une logique orientée attaquant : chaque dimension correspond à un levier que l'attaquant doit neutraliser pour progresser. Elle peut être utilisée dans un exercice de red teaming ou dans la phase d'évaluation d'une homologation au sens du guide ANSSI BP-028. Chaque dimension est notée de 0 (absent) à 3 (mature et testé).

#	Dimension	Niveau 0	Niveau 3 (cible)
1	Authentification phishing-resistant	Mot de passe + SMS	FIDO2/passkeys universel
2	Binding jeton/device	Cookie classique	DPoP ou mTLS client systématique
3	Durée de vie de jeton	≥ 8 h	≤ 15 min + rotation refresh
4	Couverture télémétrique	Logs périmétriques	SIEM + NDR + UEBA + EDR corrélés
5	Détection comportementale C2	Aucune	Modèles ML beacon + threat hunting
6	Micro-segmentation	VLAN unique	Politique L7 par charge de travail
7	Posture device	Non vérifiée	Health check continu (MDM/EDR)
8	ITDR & gouvernance IdP	Aucune	ITDR actif + revue trimestrielle IdP

Tableau 6 - Grille de maturité Zero-Trust orientée résistance à l'évasion.

Un score inférieur à 12/24 signale une architecture structurellement perméable à l'évasion sur au moins l'un des quatre vecteurs. Un score de 12 à 18 correspond à un niveau intermédiaire où la détection est possible mais requiert une intervention SOC humaine. Un score de 19 à 24 indique une maturité avancée où les contrôles sont automatisés et testés.

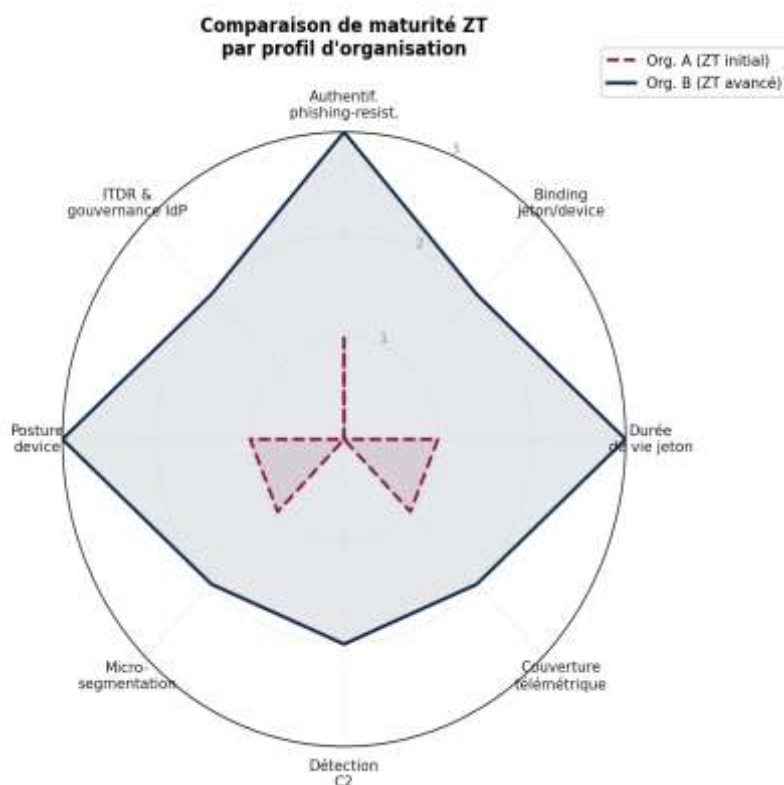


Figure 4 - Radar chart de maturité Zero-Trust pour deux profils d'organisation. L'organisation A (déploiement initial) présente de larges zones d'ombre sur les dimensions C2, binding jeton et ITDR. L'organisation B (déploiement avancé) couvre l'ensemble des dimensions à un niveau ≥ 2 .

Cette grille est destinée à être intégrée comme annexe technique dans un dossier d'homologation au sens du guide ANSSI BP-028. Elle permet au RSSI de justifier, dimension par dimension, le niveau de risque résiduel accepté face à l'évasion de détection, et de proposer un plan de remédiation priorisé. Elle peut également servir de référentiel pour un audit de conformité NIS2 sur le volet « mesures de détection » de l'article 21.

6. Conclusion et questions de recherche ouvertes

Le modèle Zero-Trust constitue une avancée nécessaire de la cybersécurité moderne, et ses principes, vérification continue, moindre privilège, supposition de compromission - sont alignés avec l'état de la menace documenté par le DBIR 2025 et les rapports d'incident majeurs des trois dernières années. Il ne constitue cependant ni une panacée, ni une technologie achetable sur étagère.

Ce rapport a documenté quatre vecteurs structurels d'évasion qui exploitent non pas des défauts d'implémentation contingents, mais des hypothèses constitutives du modèle : intégrité du fournisseur d'identité, complétude de la télémétrie, granularité effective de la micro-segmentation. Cette distinction est importante : elle implique que ces vulnérabilités ne peuvent pas être éliminées par un simple correctif ou une mise à jour de configuration, mais nécessitent une réflexion architecturale et une évolution des pratiques SOC.

L'analyse de l'incident Okta 2023 est particulièrement éloquent. Une organisation dont l'IdP est certifié ISO 27001, déployant du MFA et des jetons à durée de vie limitée, peut rester compromise pendant quatorze jours sans détecter l'intrusion, parce que le vecteur d'attaque (détournement de jeton via fichier HAR) ne produit aucune anomalie d'authentification, le signal le plus naturellement surveillé dans un SOC.

L'analyse converge pleinement avec la position de l'ANSSI dans le guide PA-111 : le Zero-Trust ne doit en aucun cas être vu comme un remplacement d'une défense périmétrique. La promesse commerciale du Zero-Trust, souvent résumée à (supprimer le VPN et déployer un ZTNA), est réductrice et potentiellement dangereuse si elle conduit à abandonner des couches de défense périmétrique sans les remplacer par des contrôles équivalents orientés comportement.

Apport original du rapport. Trois contributions sont proposées. (1) Une taxonomie des vecteurs d'évasion spécifiquement Zero-Trust, organisée autour des trois hypothèses constitutives H1, H2, H3. (2) Un scénario expérimental de rejeu de jeton démontrant l'absence de détection automatique dans une configuration out-of-the-box. (3) Une grille de maturité en huit dimensions, orientée résistance à l'évasion plutôt que conformité pilier, directement exploitable dans une démarche d'homologation ANSSI ou d'audit NIS2.

Limites et perspectives. Ce travail comporte plusieurs limites qu'une recherche de Master 2 permettrait de lever. L'environnement de laboratoire reste simplifié : un seul vecteur est expérimenté, sans infostealer réel ni trafic DoH. La grille de maturité est proposée mais non validée empiriquement. L'analyse de la micro-segmentation reste qualitative. Enfin, l'impact de l'arrivée des passkeys FIDO2 et du DPoP sur les vecteurs 1 et 4 mériterait une évaluation quantitative.

Questions de recherche ouvertes

- Q1. Comment quantifier objectivement la couverture d'une politique de micro-segmentation face au mouvement latéral dans un cluster Kubernetes dynamique, en extrapolant le cadre graphique de Basta et al. (2021) ? En particulier, comment intégrer la rotation rapide des pods et la découverte de services dans un modèle de graphe d'attaque temps-réel ?
- Q2. Quelle est la limite théorique de détection d'un canal C2 sur DoH/DoQ par analyse de timing et de jitter, et comment un adversaire informé peut-il s'en approcher par adversarial learning ? Existe-t-il un théorème d'impossibilité de détection analogue à celui de Shannon pour le chiffrement ?
- Q3. Comment intégrer la grille proposée en section 5.3 dans une démarche d'homologation ANSSI, en produisant des artefacts standardisés (kit d'audit, matrice de risque résiduel, plan de continuité) directement exploitables par un RSSI dans le cadre de sa PSSI ?
- Q4. Dans quelle mesure l'arrivée des passkeys FIDO2 universels, du DPoP et du token binding natif modifie-t-elle la surface d'attaque sur les vecteurs 1 et 4 à horizon 2027 ? Quels vecteurs émergents (attaques sur les agents IA, non-human identities) prendraient le relais ?

Ces quatre questions constituent autant de pistes que je souhaiterais explorer dans le cadre d'un Master 2 orienté cybersécurité, détection d'intrusion, ou sécurité des réseaux et systèmes. Elles s'inscrivent dans la continuité directe de ce rapport et bénéficieraient d'un encadrement académique permettant de lever les limites méthodologiques identifiées.

Références bibliographiques

Les références ci-dessous sont classées par catégorie : cadres normatifs et institutionnels, rapports d'incident et données empiriques, publications académiques, ressources techniques et outils. Toutes les sources sont publiquement accessibles à la date de rédaction.

Cadres normatifs et institutionnels

- [1] ROSE S., BORCHERT O., MITCHELL S., CONNELLY S. Zero Trust Architecture. NIST Special Publication 800-207, août 2020. DOI : 10.6028/NIST.SP.800-207.
- [2] ANSSI. Le modèle Zero Trust : les fondamentaux. ANSSI-PA-111 v1.0, juin 2025. cyber.gouv.fr/publications/zero-trust.
- [3] ANSSI. Avis scientifique et technique sur le modèle Zero Trust. [Messervices.cyber.gouv.fr](https://messervices.cyber.gouv.fr), avril 2021.
- [4] CHANDRAMOULI R., BUTCHER Z. A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments. NIST SP 800-207A, septembre 2023.
- [5] CISA. Zero Trust Maturity Model v2.0. Cybersecurity and Infrastructure Security Agency, avril 2023.
- [6] CISA. The Journey to Zero Trust: Microsegmentation in Zero Trust, Part One. Juillet 2025.
- [7] NIST. Digital Identity Guidelines. NIST SP 800-63B — Authenticator Assurance Levels (AAL1-AAL3).
- [8] ANSSI. Recommandations relatives à l'administration sécurisée des systèmes d'information. Guide ANSSI.
- [9] ANSSI. Recommandations de sécurité relatives à TLS. Guide TLS ANSSI, 2021.
- [10] ANSSI. Guide de déploiement de la segmentation réseau (BP-028). ANSSI.
- [11] CLUSIF. Que faut-il savoir sur le Zero Trust ? Document de travail, octobre 2023.
- [12] Parlement européen et Conseil de l'UE. Directive NIS2 (2022/2555), article 21. Journal officiel de l'UE, décembre 2022.

Rapports d'incident et données empiriques

- [13] VERIZON. 2025 Data Breach Investigations Report. 18e édition, analyse de 22 000+ incidents. Verizon Business, avril 2025.
- [14] IBM SECURITY. Cost of a Data Breach Report 2025. IBM, 2025.
- [15] PALO ALTO NETWORKS — UNIT 42. 2025 Global Incident Response Report. 2025.
- [16] OKTA SECURITY. Unauthorized Access to Okta's Support Case Management System: Root Cause and Remediation. sec.okta.com, 3 novembre 2023.
- [17] OKTA SECURITY. Cross-Tenant Impersonation: Prevention and Detection. sec.okta.com, 31 août 2023.
- [18] HELPNETSECURITY. Okta breach post mortem reveals weaknesses exploited by attackers. 6 novembre 2023.
- [19] RELIAQUEST. Scattered Spider Lateral Movement Analysis. Rapport ReliaQuest, novembre 2023.
- [20] VERIZON. Additional 2025 DBIR research on credential stuffing. verizon.com/business/resources/articles, 2025.

Publications académiques

- [21] BASTA N. et al. Towards a Zero-Trust Micro-segmentation Network Security Strategy: An Evaluation Framework. [arXiv:2111.10967](https://arxiv.org/abs/2111.10967), novembre 2021.
- [22] XAVIER G., NOVO C., MORLA R. Tweaking Metasploit to Evade Encrypted C2 Traffic Detection. FEUP/INESC TEC, [arXiv:2209.00943](https://arxiv.org/abs/2209.00943), 2022.
- [23] LIU Y. et al. Network microsegmentation design methodology in zero-trust architecture. CEUR Workshop Proceedings, vol. 4024, 2025.
- [24] Anonyme. A three-tier microsegmentation orchestration framework for Zero Trust Architecture. ScienceDirect, mars 2026.

Ressources techniques et frameworks

- [25] MITRE. ATT&CK Technique T1539 : Steal Web Session Cookie. attack.mitre.org.
- [26] MITRE. ATT&CK Technique T1550.004 : Web Session Cookie. attack.mitre.org.
- [27] MITRE. ATT&CK Technique T1556 : Modify Authentication Process (.006, .007, .009). attack.mitre.org.
- [28] MITRE. ATT&CK Technique T1071.004 : Application Layer Protocol — DNS. attack.mitre.org.
- [29] MITRE. ATT&CK Technique T1001.003 : Protocol or Service Impersonation. attack.mitre.org.

- [30] MITRE. ATT&CK Technique T1041 : Exfiltration Over C2 Channel. attack.mitre.org.
- [31] MICROSOFT INCIDENT RESPONSE. Token tactics: How to prevent, detect, and respond to cloud token theft. Microsoft Security Blog, novembre 2022.
- [32] ACTIVE COUNTERMEASURES. Encrypted DNS Comparison: Detecting C2 When You Can't See the Queries. Janvier 2026.
- [33] ELASTIC SECURITY. Hunting with Elastic Security: Exfiltration over C2 channel (T1041). Avril 2025.
- [34] GRETZKY K. Evilginx 2 — Next Generation of Phishing 2FA Tokens. 2018.
- [35] FIDELIS SECURITY. Command and Control (C2) Detection: Every SOC Must Know. Janvier 2026.

Note méthodologique. Ce rapport s'appuie exclusivement sur des sources primaires (NIST, ANSSI, CISA, MITRE) et des sources secondaires de référence (rapports Verizon DBIR, IBM, publications académiques peer-reviewed). Toutes les affirmations chiffrées sont attribuées à leur source d'origine. Les expérimentations décrites en section 4 sont originales et conduites par l'auteur dans un environnement isolé. La grille de maturité de la section 5.3 est une contribution originale de l'auteur, non publiée par ailleurs.